

Privacy Classification of HTTP Request Metadata for a Zero-Knowledge File Sharing Service

Privacy classification of each field

Legal framing across the regimes you listed

The pivotal question across **GDPR / UK GDPR, LGPD**, and **CCPA/CPRA** is not “does this field look like a name?”, but “does this information *relate to* an identified or *identifiable* person (or household/device), directly or indirectly?” (GDPR Art. 4(1)). ¹ Under GDPR, identifiability is assessed by looking at the “means reasonably likely to be used” (including *singling out*) by the controller or someone else (Recital 26). ²

Two consequences matter for your “full compromise = zero privacy impact” claim:

1. **Many HTTP metadata fields are “online identifiers” or “location data” under GDPR**, even when they do not name a person, because they can single out a device/user, and can be combined with other data (Recital 30; Art. 4(1)). ³
2. **Even where a single field is “low identifying” (e.g., country, language), it can become personal data in context** once stored alongside per-transfer timestamps, share IDs, or other stable event identifiers, because this enables singling out and linkability (Recital 26). ²

Under **UK GDPR**, the same broad concept applies; the UK regulator [“entity”[“organization”, “Information Commissioner’s Office”, “uk data protection regulator”]] explicitly treats IP addresses and similar online identifiers as within scope of personal data analysis (via Recital 30 / UK GDPR framing). ⁴

Under **LGPD**, “personal data” is similarly “information regarding an identified or identifiable natural person” (Art. 5(I)), and “anonymized data” is excluded only where the person cannot be identified using “reasonable technical means” (Arts. 5(III) and 12). ⁵

Under **CCPA/CPRA**, “personal information” is broadly any information that is reasonably capable of being linked to a consumer or household, and the statute explicitly recognises that personal information can include “metadata” and that it can exist as “compressed or encrypted files, metadata ... capable of outputting personal information.” ⁶ The statute also defines “precise geolocation” (1,850 feet radius) and treats it as sensitive personal information. ⁶

Finally, **ePrivacy / UK PECR** is not a “what is personal data” test; it focuses (among other topics) on *accessing/storing information on a user’s device* (cookies and similar technologies). The [“entity”[“organization”, “European Data Protection Board”, “eu data protection body”]] has clarified that device fingerprinting falls within Art. 5(3) technical scope and that “information” is broader than “personal data” for this purpose. ⁷

Field-by-field classification

Because you are storing per-transfer event JSON alongside payloads, the *breach impact* is driven by (a) whether a field is personal data, and (b) whether it enables *linkability* and *singling out*. Under GDPR

Recital 26 and Recital 30, many “metadata” fields are at least quasi-identifiers, and often personal data outright. ⁸

Below is a practical classification using your categories (**PII**, **Quasi-identifier**, **Non-personal**) and reflecting how regulators typically treat these fields in context:

- **PII (in your sense: directly or indirectly identifies a person/device/household)**

IP address; derived geolocation at city/postcode/lat-lon granularity; full referrer URLs (often); VPN/proxy/Tor status tied to a request; threat intelligence flags tied to an identifier; ISP/organisation when tied to a request; any query parameters that may contain tokens, IDs, emails, filenames, etc.

Why: GDPR explicitly treats online identifiers like IP addresses as associable with natural persons (Recital 30), and identifiability includes singling out (Recital 26). ⁹

- **Quasi-identifiers (not necessarily identifying alone, but can single out when combined)**

User-Agent; Accept-Language; timestamp; country/region/city headers; ASN; device-type flags; TLS parameters; paths/endpoints (if stable per-file); content length.

Why: these fields are common components of fingerprinting and linkability across events, and GDPR’s identifiability test explicitly includes singling out and considers combination risk. ¹⁰

- **Non-personal (generally safe as standalone technical telemetry)**

HTTP method; coarse protocol/version markers; generic error codes; coarse size buckets; high-level aggregated counters.

Caveat: Even “non-personal” fields can become personal data if logged alongside a stable per-user/per-link identifier or a fine-grained timestamp (Recital 26). ²

A more explicit mapping to your numbered list:

1. **IP address** → **PII** (GDPR treats IP as an online identifier; CJEU’s Breyer ruling shows dynamic IPs can be personal data depending on “means reasonably likely” to identify). ¹¹
2. **User-Agent** → **Quasi-identifier (often effectively PII in practice)** due to fingerprinting potential and high entropy in some populations. ¹²
3. **Accept-Language** → **Quasi-identifier** (low uniqueness alone, but contributes to fingerprinting). ¹³
4. **Referer** → **PII** in many real deployments because it can include full URLs, paths, and query parameters revealing account IDs, search terms, document names, or sharing links. (The risk is structural: you cannot control what upstream pages put in URLs.) ²
5. **Timestamp (server-side, UTC)** → **Quasi-identifier** (highly linkable; enables correlation attacks, especially when users know “I uploaded at 10:03”). GDPR identifiability includes singling out and combination risk. ²
6. **CloudFront geolocation/device headers** → mostly **Quasi-identifier** → **PII as granularity increases**. These headers are derived from viewer characteristics (often IP-based) and can include city/postcode/lat-lon/timezone/ASN; [“entity”[“company”, “Amazon Web Services”, “cloud computing provider”]] documents that CloudFront can forward device type, geolocation, and TLS connection details (and even JA3/JA4 fingerprints if enabled). ¹⁴
7. **TLS metadata (cipher suite, TLS version)** → **Quasi-identifier** (weak alone, but can contribute to fingerprinting; CloudFront can expose more fingerprint-like values depending on configuration). ¹⁵
8. **Request metadata (method, path, query params, content-length)** → mixed:
9. method → **Non-personal**;

10. path/route → **Quasi-identifier** (can become PII if it encodes per-file IDs);
11. query parameters → **often PII** (tokens/IDs);
12. content-length → **Quasi-identifier** (can leak file size patterns). ²
13. **Derived geolocation** → depends on resolution: **country** usually quasi; **city/postcode/lat-lon** often PII in context. (See geolocation section.) ⁸
14. **ISP / organisation name** → **Quasi-identifier** (and can be PII when tied to a user request). ²
15. **ASN** → **Quasi-identifier** (network-level; useful for security analytics but still linkable). ¹⁶
16. **Connection type** → **Quasi-identifier** (profiling signal). ²
17. **VPN / proxy / Tor detection** → **PII / high-risk quasi-identifier** (it is a behavioural/security attribute tied to a user session, and can create reputational harm if exposed). ²
18. **Threat intelligence flags** → **PII / high-risk quasi-identifier** when stored per request, because it encodes an assessment about a particular user/device/network and is inherently linkable. ²

Is an IP address always PII under GDPR?

Not *always*, but under GDPR it is **very often personal data in practice**, especially for online services.

- GDPR Recital 30 explicitly names “internet protocol addresses” as online identifiers that may be associated with natural persons. ¹⁷
- The decisive nuance comes from the CJEU in **Breyer v Germany (C-582/14)** involving Mr [Entity] [“people”, “Patrick Breyer”, “breyer case claimant”]: the Court held that dynamic IP addresses can be personal data for a website operator **where the operator has legal means reasonably likely to be used to identify the user using additional data held by an ISP**. ¹⁸
- The Court also stated the counterfactual: it would not be personal data in that relationship **if identification were prohibited by law or practically impossible due to disproportionate effort**, such that the risk of identification is “insignificant.” ¹⁸

So: **an IP address is not “automatically” personal data in every theoretical scenario**, but for most real-world internet services (especially where abuse/security incidents create legal routes to identification), Breyer makes it difficult to argue the IP address is non-personal. ¹⁹

The anonymisation boundary

Anonymisation vs pseudonymisation under GDPR

GDPR draws a sharp legal line:

- **Anonymous information** is out of scope: the GDPR “does not ... concern the processing” of information that does not relate to an identifiable person (Recital 26). ²
- **Pseudonymised personal data remains personal data**: Recital 26 states that personal data which have undergone pseudonymisation and could be attributed to a person using additional information “should be considered” personal data. ²
- The formal definition (Art. 4(5)) requires that attribution is no longer possible *without additional information*, kept separately and protected. ¹
- The [Entity] [“organization”, “European Data Protection Board”, “eu data protection body”] reinforces this: pseudonymised data remains personal even if the “additional information” is not held by the same person, and only becomes anonymous if the conditions for anonymity are met. ²⁰

In short: for a “full compromise = zero impact” brand promise, **pseudonymisation is usually not enough**, because it still creates breach-impactful personal data (and still enables linkability within the dataset). ²¹

Does hashing make IP addresses anonymous?

Regulators and guidance are sceptical that “just hashing” is true anonymisation.

The Article 29 Working Party’s Opinion 05/2014 (WP216) is still heavily relied upon as foundational EU anonymisation guidance. It states plainly that **pseudonymisation is not anonymisation** and discusses hashing as a typical pseudonymisation technique. ²²

WP216’s key points for hashing:

- A plain cryptographic hash is not reversible, but **if the input range is known**, attackers can replay all plausible inputs and match hashes (dictionary/brute force). ²³
- Hash functions are usually fast and therefore “subject to brute force attacks,” with precomputed tables also possible. ²³
- **Salting** reduces reversal likelihood but WP216 cautions that recovering the original attribute behind a salted hash “may still be feasible with reasonable means,” especially if the attribute type is known. ²³
- WP216 distinguishes a **keyed-hash function with stored key** (harder for attackers without the key) and also notes “deterministic encryption or keyed-hash ... with deletion of the key” as a way to reduce linkability across datasets. ²³

The `Entity["organization","European Union Agency for Cybersecurity","eu cybersecurity agency"]` also treats brute force and dictionary attacks as central threats against pseudonymisation methods. ²⁴

Is `SHA-256(IP + daily_salt)` anonymisation or pseudonymisation?

Under GDPR doctrine, this design sits in a grey zone, but you should assume **pseudonymisation unless you can justify anonymity under Recital 26**.

Key issues:

- **If the salt exists anywhere that can be obtained (in code, config, logs, backups, KMS history, CI/CD artefacts), you have not broken reidentification risk**—you have created pseudonymised personal data (GDPR Recital 26; Art. 4(5)). ²⁵
- Even if the salt is “discarded after rotation,” the resulting stored hashes still support **singling out and linkability within the rotation window** (all requests that day share a stable pseudonym). Recital 26 explicitly treats singling out as part of “means reasonably likely.” ²
- The EDPB’s pseudonymisation guidelines stress that secret parameters need real entropy; choosing predictable parameters (e.g., date) is explicitly called out as low entropy and weak. ²⁶

A defensible way to describe this to stakeholders is:

- **During processing:** you handled personal data (IP address) (Recital 30). ¹⁷
- **At rest:** you stored a dataset that may be *hard* to reverse, but still enables linkability/singling out and may still be treated as personal data (Recital 26; WP216). ²⁷

If your product promise is “zero privacy impact if S3 is dumped,” you should treat **any stable per-user pseudonym** (even if it cannot be reversed to IP) as a potential privacy impact, because it reveals behavioural patterns (“this same entity downloaded 40 times,” “this entity only ever connects at 02:00 UTC,” etc.). Recital 26’s “singling out” is the legal expression of this risk. ²

HMAC with server-held key vs SHA-256 with discarded salt

From a security engineering viewpoint, an HMAC is often more resistant to brute-force reversal than an unsalted hash because it requires the secret key. But for your **threat model (“full server compromise”)**, the key difference is:

- **HMAC with a server-held key is pseudonymisation**, and if the key is compromised, an attacker can compute the HMAC for candidate IPs (IPv4 space is limited; IPv6 is harder but still not conceptually safe). WP216 explicitly treats keyed-hash with stored key as a pseudonymisation technique, not anonymisation. ²³
- **SHA-256 with a high-entropy salt that is truly destroyed** can be stronger against reversal in the **breach-at-rest model**, because the attacker does *not* obtain the secret needed to test candidates. WP216 notes that deletion of the key in deterministic schemes reduces linkability across datasets and makes brute force infeasible without the key. ²³
- However, EDPB guidance still conceptualises this space as pseudonymisation unless/ until the anonymity conditions are met (and they require considering other parties and realistic means). ²⁸

For a “zero-knowledge dataset compromise” promise, the more defensible option is usually: **do not store any identifier-derived stable pseudonym per event at all**; compute what you need ephemeral and store only aggregated counters that meet a k-anonymity threshold. ²⁹

Geolocation granularity and the safe storage line

What the law treats as “location data” and why granularity matters

GDPR’s definition of personal data explicitly includes **“location data”** as an identifier (Art. 4(1)). ¹ GDPR also warns that device/protocol identifiers (including IP) enable identification when combined (Recital 30). ¹⁷

So the question is less “is country personal data?” and more:

- **Does this location value, in your dataset, enable singling out, linkability, or inference?** (Recital 26; WP216’s singling out/linkability/inference test). ³⁰
- **What population size does the value represent, and what other event fields are stored alongside it?** (k-anonymity is a relevant concept for the “singling out” risk). ³¹

Granularity assessment for your use cases

Country

Country is generally low risk *as a standalone attribute*, but in event logs it remains a quasi-identifier (it still “relates to” a user session and can contribute to singling out when combined with rare-country access, timestamps, or unique share IDs). The safest posture for your promise is: store country only in contexts where your analytics are aggregated and thresholded. (GDPR Recital 26/30). ⁸

Region/State

Region/state often reduces k substantially and becomes high risk in lower-population regions or niche usage cohorts. Treat as quasi-identifier at best, frequently personal data in context (Art. 4(1)'s "location data" plus Recital 26). ³²

City

City-level is frequently identifying when combined with time and any stable event identifier. CloudFront can provide city headers derived from IP; AWS explicitly notes this granularity can include city/postal/lat-lon based on IP. ³³ City should therefore be treated as personal data in most logging contexts.

Postal code / ZIP

Postal codes are a strong quasi-identifier and often effectively identifying in practice:

- In England and Wales there are ~1.6m postcodes in use, and **around 15 addresses on average per postcode** (with up to 100 in some cases), per the [Entity["organization","Office for National Statistics","uk statistics agency"]]. ³⁴
- In the US, classic work shows that combinations involving ZIP code can uniquely identify a large share of people (e.g., demographics + ZIP + birthdate); even though you are not collecting birthdate, this shows why ZIP is treated as a dangerous quasi-identifier. ³⁵

For your threat model, **postal code should not be stored per transfer event.**

Latitude/Longitude (IP-derived "city-level" coordinates)

Even if IP geolocation lat/lon is only approximate, it is still location data tied to an online identifier, and it can dramatically reduce k in rural areas or small towns. Treat as personal data in most contexts (Art. 4(1); Recital 30). ³⁶

"Precise geolocation" (CPRA concept)

CPRA defines "precise geolocation" as locating a consumer within a circle of radius 1,850 feet, and treats "precise geolocation" as sensitive personal information. ⁶ Your IP-derived lat/lon is typically *less precise* than this, but under GDPR the "precise / not precise" distinction is not a safe harbour; it remains location data and can still be personal data depending on identifiability.

Where is the "safe storage line"?

For a privacy-first service that wants "zero privacy impact if S3 is dumped," the most defensible "safe line" is:

- **Store at most: country code (and only if you also apply k -thresholding in analytics outputs).**
- **Do not store: city, postcode, lat/lon, or anything at household-level granularity.**

A practical way to operationalise this is to apply **k -anonymity (or suppression) to location analytics outputs**, not to raw event logs. The ICO's anonymisation materials define k -anonymity and treat "indirect identifiers" (quasi-identifiers) as central to re-identification risk. ³¹

What k is "generally accepted"?

There is **no universal regulator-set k** in GDPR/UK GDPR. Recital 26 frames a contextual "means reasonably likely" test, not a numeric threshold. ²

However, **k=5** is a common minimum starting point in practice, and the ICO's own anonymisation case study uses **k = 5** as an example design choice (illustrating a conservative minimum group size before releasing/using granular breakdowns). ³⁷ For a public-facing dashboard or any exported analytics, many organisations choose higher thresholds (10, 20, 50+) depending on sensitivity and auxiliary data risk; but for your breach-threat model, the bigger issue is *not publishing*, it's *not storing event-level quasi-identifiers at all*. ³⁰

What to store vs derive vs discard

Your constraints (privacy-first, no marketing tracking, threat model includes full S3 exposure) align strongly with GDPR's **data minimisation** and **storage limitation** principles: collect only what you need and keep it only as long as necessary. ³⁸

The design goal "entire server-side dataset can be exposed with zero privacy impact" is stricter than most legal compliance baselines. Practically, you want to ensure that your persisted dataset contains **no online identifiers, no stable pseudonyms, and no high-resolution behavioural traces**.

Tier 1 — Store in plaintext

Store only fields that are operationally necessary and low-risk even if exposed, and ensure they are **coarsened** to reduce singling out:

- **Event type**: upload/download, success/failure, HTTP status family.
- **Coarsened timestamp**: e.g., date-only (YYYY-MM-DD) or hour bucket, depending on analytics need; avoid exact timestamps where feasible because they enable correlation. (Singling out risk under Recital 26.) ³⁹
- **Country code** (ISO) *only if you will threshold or aggregate outputs*; avoid storing more granular location. (Recital 30 + location as identifier under Art. 4(1).) ³
- **Device class**: mobile/desktop/tablet flags, because these are low entropy and useful for UX/ support. (But still treat as quasi-identifier in combination.) ¹⁶
- **TLS version (major.minor)**: generally non-personal telemetry; avoid storing TLS fingerprints like JA3/JA4 if you aim to minimise fingerprinting. AWS notes those can be forwarded as headers depending on configuration. ⁴⁰
- **API route template name** rather than raw path, and **never store query parameters**. Query parameters are a common leak vector for identifiers. ²
- **Size/bandwidth buckets** (e.g., 0–1MB, 1–10MB, etc.) instead of exact content-length if you want to reduce inference from exact file sizes.

Tier 2 — Store as anonymised hash

For your stated promise, the safest recommendation is: **avoid Tier 2 entirely in persisted per-event logs**.

Reason: hashing that preserves per-user stability (even temporarily) preserves **linkability/singling out**, which is enough to create privacy impact (GDPR Recital 26; WP216). ⁴¹

If you decide you must support limited analytics like “same network downloaded repeatedly” without storing raw IP, then (and only then) Tier 2 should be designed to minimise both reversibility and linkability:

- Prefer **very short retention** (hours/days) and destruction of secrets, rather than indefinite retention of hashed identifiers.
- Do not use predictable “salts” (like date strings); the EDPB cautions about low entropy secret parameters. ²⁶
- Recognise that this is still usually **pseudonymisation**, not anonymisation (WP216; GDPR Recital 26; EDPB 01/2025). ⁴²

What analytics are possible from *stored* hashes depends on the stability window:

- Stable within a day → can count “unique pseudonyms per day” and detect bursts from one source that day.
- Rotating or per-object salts → reduces cross-day linkability but also reduces longitudinal analytics.

Given your threat model, a more privacy-preserving alternative is to **derive analytics outside the per-file event log** (e.g., aggregate counts by country/day) and store only aggregated outputs that meet k-thresholds.

Tier 3 — Never store

To keep your dataset safe-to-dump:

- **Never store raw IP addresses.** They are online identifiers and often personal data (Recital 30; Breyer). ⁴³
- **Never store full User-Agent strings.** They can carry significant identifying entropy (EFF research) and enable fingerprinting. ⁴⁴
- **Never store referer URLs.** They can exfiltrate identifiers and link secrets; they are high-risk by design. ²
- **Never store query parameters.** Treat as potentially sensitive. ²
- **Never store city/postcode/lat-lon.** These are strong quasi-identifiers and often personal data in context. ⁴⁵
- **Avoid storing ASN/ISP unless you can justify a strong necessity**, and prefer to store only coarse derived categories (e.g., “hosting vs residential”) if needed—and even then, consider whether exposing that attribute creates user harm. (Profiling considerations; Recital 26/30 logic.) ⁸
- **Threat intelligence / VPN-Tor flags** should not be stored per request in a “zero-impact breach” dataset, because they encode behavioural/security judgments about a particular user/session. ²

You can still use these fields **ephemerally** (in-memory, during request processing) for rate limiting, abuse detection, and showing users the transparency panel—just do not persist them.

User-Agent and fingerprinting risk

User-Agent strings are a well-known fingerprint component. The key question is not “is it a name?” but “how much entropy does it convey, and how linkable is it when combined with other fields (language, timezone, TLS details, etc.)?”

The [entity["organization","Electronic Frontier Foundation","digital rights ngo"]] has long published measurements showing UA strings can be surprisingly identifying. In a 2009 dataset discussed by EFF, User-Agent strings conveyed about **10.5 bits of identifying information on average**, meaning they could single out people within crowds of ~1,000+ in that dataset. ⁴⁶ Their broader Panopticlick work finds much higher entropy when combining multiple browser attributes, and shows high uniqueness rates in certain populations. ⁴⁷

What to store instead of full User-Agent

For your use cases (abuse detection, basic analytics, transparency), storing a full UA is unnecessary. A practical, privacy-preserving approach is:

- **Do not store the raw UA.**
- If you need device analytics, store only a **normalised UA classification** such as:
 - browser family (Chrome/Safari/Firefox/Edge)
 - OS family (Windows/macOS/iOS/Android/Linux)
 - device class (mobile/desktop/tablet)
 - optionally *major version only* (e.g., "Chrome 122"), but consider whether you need it at all.

This aligns with the principle of limiting data to what is necessary. ⁴⁸ It also avoids turning your per-event metadata into a fingerprint dataset (an ePrivacy/GDPR risk highlighted in EU guidance on fingerprinting). ⁴⁹

Notably, even EU guidance examples about privacy protection include replacing user agent details with dummy data in some contexts, illustrating that user-agent is treated as identifying traffic metadata in practice. ⁵⁰

If you still want "same browser family downloaded" analytics without identifying, **store only the normalised family strings (not hashed)**. Hashing a high-entropy UA often preserves uniqueness and therefore preserves linkability—hashing does not automatically reduce privacy risk. ²⁷

Transparency panel implications

Can you show metadata live without storing it?

Yes—**technically and legally**, "show-then-discard" is usually the most privacy-aligned design for your transparency panel, with two important clarifications:

1. **Displaying it is still "processing."** GDPR defines processing broadly to include collection, use, consultation, disclosure, etc. (Art. 4(2)). ¹ So you still need a lawful basis and transparency notices, even if you don't store the data.
2. **Not storing is generally positive under minimisation and storage limitation** (Art. 5(1)(c) and (e)), because it reduces the volume of personal data at rest and therefore reduces breach impact.

³⁸

There is **no general rule** in GDPR/UK GDPR that "if you show it, you must store it." The GDPR is oriented towards minimising stored personal data, not mandating retention. (The retention principle is "no longer than necessary.") ⁵¹

What about “do we need to store what we show” for compliance/auditing?

Under GDPR accountability, you must be able to demonstrate compliance, but this is typically achieved via **records of processing, policies, and controls**, not by retaining the personal data you displayed. Consumers’ access rights apply to personal data you process, but if you genuinely do not retain a field, you cannot provide it later—this is not automatically unlawful if your retention choice is justified by minimisation and you are transparent about it. (Recital 26 / Art. 5 principles; ICO minimisation and storage limitation guidance.) ⁵²

Under LGPD, “anonymized data” is excluded only where reversal would require unreasonable effort, and the law recognises reasonable technical means and cost/time factors in the anonymity assessment. ⁵³ That logic is compatible with “derive live data, do not persist raw identifiers.”

For ePrivacy/PECR, the main caution is: if the transparency panel collects additional fingerprinting signals (beyond standard headers) via scripts, device fingerprinting can trigger Art. 5(3) considerations (EDPB guidance). ⁵⁴ A transparency panel that merely displays what the HTTP request already contained (and does not add tracking) is typically easier to justify.

Practical recommendation table

The table below assumes your stated goals: UK/EU baseline compliance, privacy-first posture, no marketing tracking, and a breach model where **S3 objects are exposed**. It also assumes the transparency panel can display live-derived values and you deliberately avoid persisting identifying metadata.

FIELD STORED	SHOW TO USER	STORE ON SERVER	FORMAT
IP address after request	Yes	Never store	Discard
(Used			
ephemerally for abuse/rate limiting only)			
User-Agent	Yes	Yes (minimised)	
Normalised: {browser_family, os_family}			+
device_class; no raw UA string			
Accept-Language	Yes	Yes (minimised)	Primary
language tag only (e.g., "en")			
Timestamp	Yes	Yes (coarsened)	UTC date
or hour-bucket (no exact seconds)			
Country	Yes	Yes	ISO country
code (e.g., "GB")			
Region/State	Yes (optional)	Prefer not	If needed:
coarse region + k-thresholding			
City	Yes (optional)	Never store	Discard
Postal code	Yes (optional)	Never store	Discard
Latitude/Longitude	Yes (optional)	Never store	Discard
ISP/Organisation	Yes (optional)	Prefer not	Discard
(or store only coarse "hosting/residential")			
ASN	Yes (optional)	Prefer not	Discard

(or store only coarse risk category)			
Connection type	Yes (optional)	Prefer not	Discard
(or store coarse bucket only)			
VPN/Proxy/Tor flag	Yes (optional)	Prefer not	Discard
(store only ephemeral decision)			
Device type (mobile/desktop)	Yes	Yes	
device_class enum			
TLS version	Yes	Yes	
tls_version_major_minor (e.g., "1.3")			

Why this table is conservative:

- IP addresses are explicitly called out as online identifiers in GDPR Recital 30, and Breyer confirms dynamic IP addresses can be personal data where identification is reasonably likely via legal means. ⁴³
- Data that enables singling out/linkability remains problematic for your “zero-impact breach” promise (Recital 26; WP216). ³⁰
- Full UA strings are fingerprinting vectors; EFF shows substantial identifying entropy for UA alone, and Panopticlick demonstrates high uniqueness when multiple attributes are combined. ⁴⁴
- Postcode-level location is near-household granularity in the UK (ONS: ~15 addresses per postcode on average), making it high-risk to store per event. ³⁴
- CPRA treats precise geolocation (<1,850 feet radius) as sensitive personal information, underscoring how location precision increases regulatory sensitivity; even if IP geolocation is less precise, GDPR still treats location data as an identifier (Art. 4(1)). ⁵⁵
- ePrivacy/PECR risk is especially relevant if you add fingerprinting beyond ordinary request handling; EU guidance confirms fingerprinting is within Art. 5(3) scope. ⁵⁴

This approach (live display, minimal storage) is the closest match to your core promise, and it aligns naturally with minimisation and storage limitation principles as interpreted by the ICO. ³⁸

1 2 3 8 9 10 11 16 17 21 25 27 30 32 36 39 41 43 45 52 REGULATION (EU) 2016/ 679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL - of 27 April 2016 - on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/ 46/ EC (General Data Protection Regulation)

<https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX%3A32016R0679>

4 What is personal data? | ICO

https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/personal-information-what-is-it/what-is-personal-data/what-is-personal-data/?utm_source=chatgpt.com

5 53 Capa LGPD em inglês 2

<https://www.gov.br/anpd/pt-br/centrais-de-conteudo/outros-documentos-e-publicacoes-institucionais/lgpd-en-lei-no-13-709-capa.pdf>

6 55 California Consumer Privacy Act of 2018

https://coppa.ca.gov/regulations/pdf/ccpa_statute.pdf

7 54 edpb.europa.eu

<https://www.edpb.europa.eu/system/files/2024-10/>

[edpb_guidelines_202302_technical_scope_art_53_eprivacydirective_v2_en_0.pdf](#)

12 44 46 **Browser Versions Carry 10.5 Bits of Identifying Information on Average | Electronic Frontier Foundation**

<https://www.eff.org/deeplinks/2010/01/tracking-by-user-agent>

13 47 **coveryourtracks.eff.org**

<https://coveryourtracks.eff.org/static/browser-uniqueness.pdf>

14 15 40 **Add CloudFront request headers**

https://docs.aws.amazon.com/AmazonCloudFront/latest/DeveloperGuide/adding-cloudfront-headers.html?utm_source=chatgpt.com

18 19 **eur-lex.europa.eu**

<https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX%3A62014CJ0582>

20 26 28 50 **edpb.europa.eu**

https://www.edpb.europa.eu/system/files/2025-01/edpb_guidelines_202501_pseudonymisation_en.pdf

22 23 42 **xxxx/xx/EN**

https://ec.europa.eu/justice/article-29/documentation/opinion-recommendation/files/2014/wp216_en.pdf

24 **Pseudonymisation techniques and best practices | ENISA**

https://www.enisa.europa.eu/publications/pseudonymisation-techniques-and-best-practices?utm_source=chatgpt.com

29 38 48 **Principle (c): Data minimisation | ICO**

https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-protection-principles/a-guide-to-the-data-protection-principles/data-minimisation/?utm_source=chatgpt.com

31 **Glossary | ICO**

https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-sharing/anonymisation/glossary/?utm_source=chatgpt.com

33 **Amazon CloudFront adds additional geolocation headers ...**

https://aws.amazon.com/about-aws/whats-new/2020/07/cloudfront-geolocation-headers/?utm_source=chatgpt.com

34 **List of postcodes and corresponding local authorities**

https://www.ons.gov.uk/aboutus/transparencyandgovernance/freedomofinformationfoi/listofpostcodesandcorrespondinglocalauthorities?utm_source=chatgpt.com

35 **Simple Demographics Often Identify People Uniquely**

https://dataprivacylab.org/projects/identifiability/paper1.pdf?utm_source=chatgpt.com

37 **pseudonymising employee data for recruitment analytics**

https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-sharing/anonymisation/case-studies-on-pseudonymisation-and-anonymisation-techniques/case-study-pseudonymising-employee-data-for-recruitment-analytics/?search=mapping+the+concept+of+the+spectrum&utm_source=chatgpt.com

49 **dataprotection.ro**

<https://www.dataprotection.ro/servlet/ViewDocument?id=1089>

51 **Principle (e): Storage limitation | ICO**

https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-protection-principles/a-guide-to-the-data-protection-principles/storage-limitation/?utm_source=chatgpt.com